Rapporto di valutazione del rischio di sicurezza

Parte 1: scegliere fino a tre strumenti e metodi di hardening da attuare

Le vulnerabilità trovate erano: password deboli o condivise tra più persone, mancanza di un secondo passaggio di verifica all'accesso e regole del firewall non aggiornate. Tre misure di hardening che le affrontano sono:

1. L'autenticazione a più fattori (MFA), che chiede all'utente più di una prova della propria identità, per esempio una password più un'impronta digitale, una tessera o un codice.

2. Una policy delle password, con regole su lunghezza e caratteri ammessi, il divieto di condividere le password e un limite ai tentativi di accesso falliti (per esempio, l'account viene bloccato dopo cinque errori).

3. Una manutenzione regolare del firewall, cioè controllare le regole e aggiornarle perché siano adatte alle minacce attuali.

Parte 2: spiegare le raccomandazioni

L'MFA aggiunge un livello sopra la password. Un attacco a forza bruta da solo non basta più, perché all'attaccante serve anche il secondo fattore. Inoltre rende inutile condividere una password, perché l'altra persona non avrebbe il secondo fattore.

Una policy delle password rende la rete più difficile da violare. Bloccare un account dopo pochi tentativi falliti ferma gli attacchi a forza bruta, e password più lunghe e complesse, che non si possono riusare né condividere, rendono molto più difficile indovinarle. Le persone sbaglieranno comunque, ma la policy elimina gli errori più comuni.

La manutenzione del firewall mantiene aggiornate le regole sul traffico consentito e negato. Le fonti sospette vanno in una lista di blocco, e le regole vengono riviste dopo ogni evento di sicurezza, soprattutto se ha lasciato passare traffico sospetto. Questo aiuta contro gli attacchi DoS e DDoS.